# Technical audit — Nhill (baseline 0.1.0, target version 2.0.0)

> **Date:** 26 October 2026 · **Scope:** complete repository delivered (`nhill-0.1.0-src.tar.gz`) and the 0.1.0 deliverables (`nhill-release/`) · **Method:** full read of the tree, automatic measurements (lines, routes, tables, tests), execution of the tests that could run, execution of the delivered 0.1.0 binaries under Xvfb. **Major limit of the audit environment:** only GitHub is reachable; the Ubuntu/Debian, Qt, PyPI, npm and Google repositories are blocked, and the session security policy refused to build the dependencies from their sources. The complete project (server + Qt applications) **could therefore not be rebuilt here**. What was executed is stated explicitly.

## 1. Summary

Nhill is a multi-establishment business management suite written in **C++17**: an HTTP/JSON server and three **Qt 6 Quick (QML)** applications sharing one library. Overall quality is **good and above average** for a product at this stage: clean client/server split, exact money arithmetic in minor units, establishment isolation through forced PostgreSQL *row-level security*, versioned migrations with checksums, audit logging, real integration tests against a throwaway PostgreSQL.

The main weaknesses are not in the business logic but in:

1. **the delivery chain** (Windows and Android never built; Debian 13 packages built on Ubuntu with a frozen embedded Qt runtime that receives no security updates);
2. **presentation ergonomics** (fixed window sizes, truncated tables, insufficient contrast — see the UI/UX audit);
3. **vulnerable embedded dependencies** (cpp-httplib 0.14, frozen Qt 6.4.2 — see the security audit);
4. **no account recovery path** (no e-mail delivery).

| Area | Assessment | Highlights |
|---|---|---|
| Architecture | Solid | Thin clients, authoritative server, one code base for 3 applications |
| Business logic | Solid, tested | Exact amounts, taxes, transactional numbering, issued documents immutable |
| Data | Solid | 10 migrations, 64 tables, RLS forced on 30 business tables |
| Tests | Good | 4 suites (common, server, setup, client); 0.1.0: 119 tests, 1 skipped |
| Build | Fragile | Only Linux built; reliance on scripts outside the repository (fixed in 2.0.0) |
| Distribution | Incomplete (0.1.0) | Windows/Android not built; Debian 13 with embedded runtime — fixed in 2.0.0: Windows installers, APK, native Debian 13 packages built in CI (validation report) |
| Observability | Minimal | `/health`, systemd journal, console “Technical errors” |

## 2. Inventory

### 2.1 Languages, standards and size

| Item | Measured value |
|---|---|
| Language | C++17 (`CMAKE_CXX_STANDARD 17`, extensions off) |
| Server | 10,765 lines of C++ (`server/src`), **182 HTTP routes** registered |
| Client (C++) | 1,500 lines (`client/src/core`, 3 `main.cpp`) |
| Client (QML) | 8,955 lines, 95 files, 4 modules (`Nhill.Ui`, `Nhill.Business`, `Nhill.Console`, `Nhill.Pos`) |
| Shared library | `common/`: money, establishment codes, validation (≈ 690 lines) |
| Database | 10 SQL migrations (1,709 lines), **64 tables**, dedicated `nhill` schema |
| Translations | `client/i18n/nhill_fr.ts` / `nhill_en.ts` (≈ 1,900 messages), `server/i18n/{fr,en}.json` |

## 2.2 Frameworks and libraries

| Component | Used by | Reference version (0.1.0) | Note |
|---|---|---|---|
| Qt 6 (Core, Gui, Network, Qml, Quick, QuickControls2, Svg, LinguistTools, Test) | Client | 6.4.2 (Ubuntu 24.04) | "Basic" style, in-house `Fb*` components |
| QtKeychain (Qt 6) | Client | 0.14 (optional) | Refresh tokens in the OS keychain; no clear-text fallback |
| libpqxx | Server | 7.8 | PostgreSQL access |
| PostgreSQL | Server | 15+ (tests: 16; production: Supabase 17.6) | Forced RLS, dedicated roles |
| cpp-httplib | Server, client tests | 0.14 | **Vulnerable** (CVE-2025-46728, CVE-2025-53629), see security audit |
| nlohmann/json | Server | ≥ 3.10 | |
| libsodium | Server | 1.0.18 | Argon2id, secretbox, HMAC |
| OpenSSL | Server | 3.x | Hashes, outbound TLS (payment providers) |
| libharu (libhpdf) | Server | 2.3.0 | Invoice, receipt and report PDFs |
| libpng | Server | 1.6 | Logos |
| GoogleTest | Tests | 1.14 | |

## 2.3 Modules and entry points

```
common/            nhill_common (static)     money, taxes, conversions, codes, validation
server/src/        nhill_server_core + nhill-server
  main.cpp           sub-commands: serve, migrate, setup (installation mode)
  http/app.*         HTTP server, context, role permissions, JSON errors
  services/*.cpp     auth, establishments, members, subscriptions, providers, console,
                     support, POS, catalogue, parties, stock, sales, purchases, payments,
                     expenses, reports, activity, administration
  pdf/, jobs/, setup.cpp, migrate.cpp, util/crypto.cpp
client/src/        nhill_client_core (ApiClient, Session, Formatter, Validator, AppContext)
  business/ pos/ console/ main.cpp   three executables
client/qml/Nhill/  Ui (components), Business, Console, Pos (screens)
db/migrations/     versioned schema 0001–0010 (SHA-256 checksums verified)
tests/             common/, server/ (API + throwaway PostgreSQL, installation), client/
deploy/            systemd, Caddy (TLS), encrypted backup/restore
```

## 2.4 Build system

- **CMake ≥ 3.21 + Ninja**, options `NHILL_BUILD_SERVER/CLIENT/TESTS`, `NHILL_WARNINGS_AS_ERRORS`. Strict warnings (`-Wall -Wextra`, `/W4`).
- QML modules compiled by `qt_add_qml_module` (qmlcachegen); resources (IBM Plex fonts, SVG logos) embedded; translations compiled by `qt_add_lrelease`.
- Packages: CPack (`cmake/NhillPackaging.cmake`) and, in the 0.1.0 deliverables, `build-deb.sh` / `build-deb-debian13.sh` scripts **located outside the source repository** (fixed: moved into `packaging/` in 2.0.0).
- Windows: PowerShell script + NSIS/Inno Setup **never executed**; Android: `build-android.sh` **never executed**.

## 2.5 System dependencies (runtime)

- **Applications:** Qt 6 and its QML modules, xcb (X11) or Wayland platform plugin, OpenGL, fontconfig, D-Bus/Secret Service (keychain).
- **Server:** libpq5, libsodium23, libssl3, libhpdf, libpng, zlib, systemd, `nhill` system user.
- Check performed: the delivered 0.1.0 binaries start here with the embedded Qt runtime; this machine lacks `libOpenGL.so.0` and `libb2.so.1` (provided by `libopengl0` and `libb2-1` on a normal machine; replaced here by test shims).

### 2.6 Database

- PostgreSQL 15+; `nhill` schema closed to `PUBLIC`, `anon`, `authenticated`, `service_role`.
- Roles: `nhill_owner` (migrations), `nhill_app` (application, `NOBYPASSRLS`, owns no object), `nhill_backup` (backups).
- RLS forced on 30 business tables (`establishment_id = nh_current_establishment()`), composite foreign keys preventing cross-establishment references.
- 18 platform tables without RLS by design (sessions, subscriptions, logs…), protected by the server's queries (review documented in `docs/archive/securite.md`).
- Immutable migrations: a migration changed after being applied is refused.

### 2.7 Configuration

- Server: `/etc/nhill/server.env` (0600, refused if readable by others), `NH_*` variables (database, listening address, secrets, Argon2, token lifetimes, background jobs). Example without secrets: `config/server.env.example`.
- Clients: Qt preferences (`QSettings`) — server address, language, theme. **No business data is stored locally**, no database secret in the applications.
- Installation mode: a server without a database starts in `setup` mode and prints a one-time token in its log; Nhill Console drives the installation.

### 2.8 Authentication, authorisation, sessions

- Argon2id passwords (libsodium, 3 passes, 64 MiB), constant-time comparison, dummy hash for unknown e-mails.
- Opaque tokens (32 bytes) stored as SHA-256; access 15 min, refresh 30 days with rotation and reuse detection (family revocation).
- Establishment roles: `owner`, `admin`, `manager`, `sales`, `accountant`, `viewer`, `cash_manager`, `cashier`; permissions checked server-side (`App::roleHas`).
- Console: separate accounts, password + **mandatory TOTP**, roles `superadmin`, `billing`, `support`, `auditor`, token in memory only.
- Rate limiting (login, codes, invitations, console, POS…) stored in the database (`auth_throttle`), so it holds across processes.
- **Gap:** no "forgot password" flow (no e-mail transport).

### 2.9 Errors and logs

- Normalised JSON API errors (`code`, `message`, `details`, `request_id`); SQL errors mapped (RLS → 404 without leaking, constraints → stable codes).
- Logs on standard output (journald); "log transport" e-mails masked.
- The applications send their QML errors to the server (personal data masked); the console groups them by fingerprint.
- **Finding:** these reports revealed two real errors in 0.1.0 (TypeError in `PosSession.qml` and `total` of `null` in Nhill Business); the first one is fixed in 2.0.0.

### 2.10 Network, resources, online operation

- HTTP/JSON on `/api/v1`, TLS terminated by Caddy (HSTS, security headers, 6 MB body limit); the server listens on 127.0.0.1 only.
- **Online-only operation**: no offline mode (documented choice: stock, numbering and rights are arbitrated by the server). POS sales are protected against duplicates by an idempotency key. A strong constraint for the target market (see the market study).

## 3. Initial build and test status (baseline)

| Check | Result | Status |
|---|---|---|
| Business tests `tests/common` (20 tests in 2.0.0, 18 in 0.1.0) built with g++ 13 and a GoogleTest-compatible runner (`scripts/test-common-standalone.sh`) | 0.1.0: **18/18 passed**; 2.0.0: **20/20 passed** | Done and tested |
| QML static check (`scripts/qa/qml-check.py`: delimiter balance, JavaScript parsing of 4,201 bindings/functions by Node.js, modules, translations) | 0.1.0: 0 errors; 2.0.0: 0 errors, 0 untranslated strings | Done and tested |

| Check | Result | Status |
|---|---|---|
| Start of the delivered 0.1.0 binaries (Xvfb 1366×768) | Nhill POS, Business, Console start and show the sign-in screen | Done and tested |
| Full build (server + clients) and `ctest` | **Not executable here** (dependencies unavailable) | Blocked — run by the provided CI (`.github/workflows/ci.yml`) |
| Project test report 0.1.0 | 18 + 82 (1 skipped) + 6 + 13 passed | Taken from `docs/archive/rapport-tests.md` |

## 4. Defects and technical debt found

| # | Finding | Severity | 2.0.0 treatment |
|---|---|---|---|
| T1 | Packaging scripts of the 0.1.0 delivery outside the source repository | Medium | Moved into `packaging/`; versions read from `CMakeLists.txt` |
| T2 | Server tests tied to `/usr/lib/postgresql/16` (fail on Debian 13, PostgreSQL 17) | Medium | Automatic version detection (`pgBinDir`) |
| T3 | Windows and Android never built | High (distribution) | Reproducible CI workflows; to be run (see the build guide) |
| T4 | Debian 13 packages with frozen embedded Qt 6.4.2/ICU/libjpeg | High (security) | Native Debian 13 build (system Qt 6.8) in CI; embedded variant discouraged |
| T5 | Vulnerable cpp-httplib 0.14 (DoS through chunked bodies) | High | Mitigated by Caddy (`request_body max_size`); upgrade to ≥ 0.23 recommended (not done: cannot be tested here) |
| T6 | Fixed window sizes (1280×800/820, 1320×840) | High (UX) | Screen-fitted size, centring, maximised on small screens |
| T7 | `X-Forwarded-For` read from the left (forgeable behind an appending proxy) | Low (the provided Caddy replaces the header) | Right-most entry used |
| T8 | POS, support and console actions without labels in the activity log | Medium (UX/traceability) | 51 FR/EN labels added; technical identifiers hidden |
| T9 | No account recovery path | High (operations) | Not fixed (needs e-mail delivery) — design proposed, to be planned |
| T10 | No offline mode | Medium (market) | Out of 2.0.0 scope (architecture change) |
| T11 | No DGI standardised invoicing (SFE/DEF) | High (DRC compliance) | Out of scope; homologation roadmap |
| T12 | Duplicated `scripts/build-*.ps1/sh` and deliverables | Low | Single entry point in `scripts/`, implementation in `packaging/` |
| T13 | QML fields whose width depends on the typed text (unbalanced grids) | Medium (UX) | Stable preferred width for fields |
| T14 | Race in the POS ticket dialog (`full` null) | Medium | Guard added |
| T15 | No QML checking tool without Qt | Low | `scripts/qa/qml-check.py` |

## 5. 2.0.0 changes that may affect business behaviour

In line with the rule of preserving business logic, every change is listed with its justification and its test:

| Change | Justification | Business effect | Test |
|---|---|---|---|
| Minimum password length 10 → **8** (14 → 8 for the console) | Requirement of the product owner | Authentication rule relaxed; refusal of common, repetitive or e-mail-equal passwords **kept**; console TOTP **kept** | `Validation.PasswordMinimumIsEightCharacters`, `Validation.PasswordBlocklistCoversEightCharacterFavourites` (run), `Auth.PasswordMinimumIsEightCharactersOnEveryPath`, `Admin.ConsoleFirstAccessAcceptsEightCharactersWithTotp` (CI) |
| Extended list of common passwords (8–9 characters) | Compensates the shorter length | A few weak passwords refused | Tests above |
| `X-Forwarded-For`: right-most entry | Security fix | Reliable per-IP limits whatever the proxy | Logic tested in isolation (6 cases) |
| Activity log summary without technical identifiers | Readability, minimisation | None (raw data unchanged in the database and the API) | Code review |
| Cash count check before closing a POS session | The server already requires it (`cash_count_required`) | None (earlier message) | Code review |

No change to calculations, data model, migrations, invoicing and subscription rules, permissions or API formats.

## 6. Prioritised recommendations

1. **Run the provided CI** (build, 4 test suites, native Ubuntu 24.04 and Debian 13 packages, Windows, Android) and publish the artefacts — the only step that turns the 2.0.0 code into verified deliverables.
2. Upgrade cpp-httplib (≥ 0.23, single header vendored in the repository) and drop the embedded Qt runtime for Debian 13.
3. Implement e-mail delivery (SMTP) then password reset (single-use, short-lived link, 8-character rule).
4. Start the SFE/DEF homologation with the DGI before targeting VAT-registered businesses.
5. Study a degraded offline mode for Nhill POS (encrypted local queue, provisional numbering) — an architecture change to design carefully.
6. Add monitoring (metrics, backup alerts) before going to production.